Blueprint Box : Un guide de pentest TryHackMe

Un guide d'apprentissage étape par étape réalisé par Rabia Yasmine — du repérage à l'extraction d'identifiants.



Made with GAMMA

Reconnaissance : Identification des ports ouverts



Ce que nous avons trouvé

Une analyse efficace cible des ports spécifiques plutôt que les 65 000 ports afin de gagner du temps et des ressources. Une approche ciblée permet d'obtenir plus rapidement des résultats exploitables.

- Découverte d'un serveur web Microsoft et d'un serveur MySQL sur des ports ouverts
- Le port 8080 héberge une application web vulnérable nécessitant une exploitation
- L'empreinte des services révèle les versions logicielles pour faire correspondre les vulnérabilités

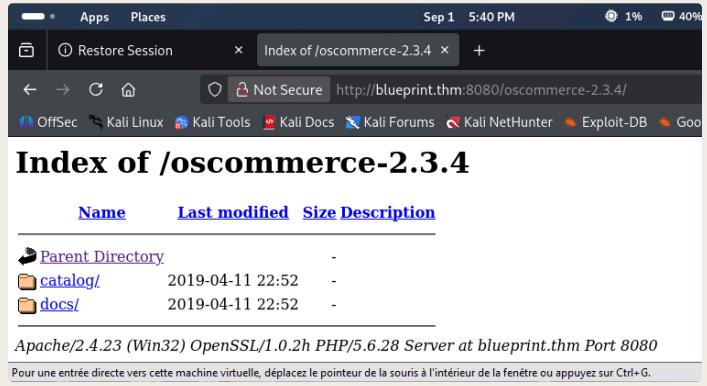
> Commencez toujours chaque mission par une analyse approfondie des ports — on ne peut pas exploiter ce que l'on n'a pas trouvé.

Made with GAMMA

Évaluation des vulnérabilités : analyse du serveur web

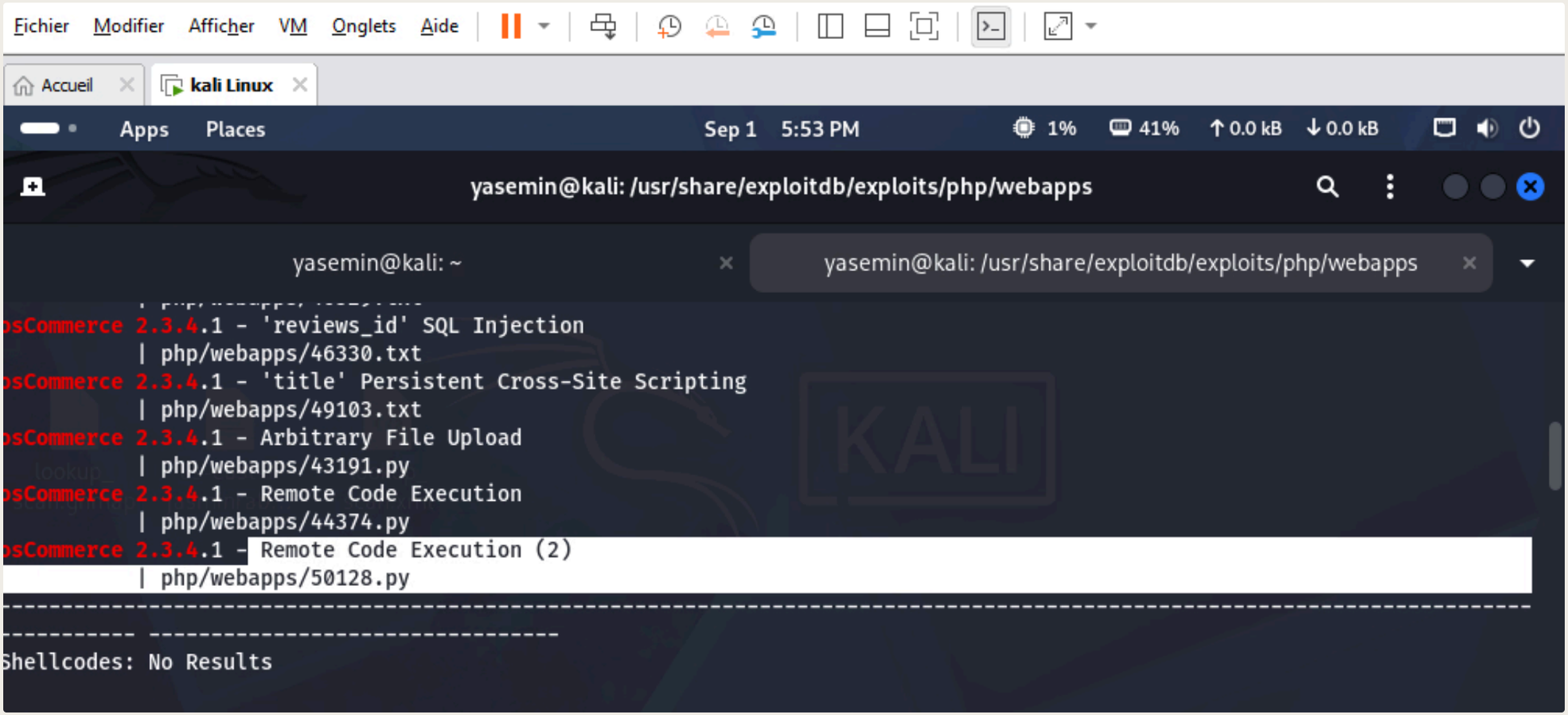
Profil de la cible

- **Application :** OSCommerce 2.3.4 exécuté sur le port 8080
- **Niveau de risque :** Critique — cette version du CMS contient des vulnérabilités bien documentées
- **Liste des répertoires :** Exposée, révélant la structure de l'application et les points d'entrée



Une mauvaise configuration de la liste des répertoires est une erreur classique que les attaquants exploitent pour cartographier rapidement les systèmes cibles avant de lancer une exploitation.

Made with GAMMA



Exploitation : Exécution de code à distance

Étape 1 : Recherche

Interrogé des bases de données d'exploits pour identifier des vulnérabilités connues d'OSCommerce ciblant l'injection SQL et l'exécution de code à distance.

Étape 2 : Exécution

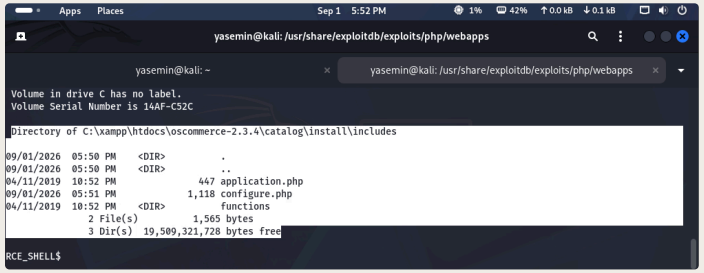
Exécuté un script d'exploitation Python directement contre l'adresse IP cible sur le port 8080.

Étape 3 : Shell

Obtenu avec succès un shell web avec des privilèges système — exécution complète du code atteinte.

Made with GAMMA

Post-exploitation : accès au système



Ce que débloque le web shell

Une fois le web shell établi, l'attaquant peut naviguer librement dans le système de fichiers, transformant une seule vulnérabilité en visibilité complète sur le serveur.

- Parcourir les répertoires et énumérer les fichiers sensibles
- Lire les données de configuration, y compris les identifiants de base de données
- Illustrer l'impact concret et critique d'une exploitation RCE réussie

⊗ Une seule application non corrigée peut exposer tout le système de fichiers d'un serveur — c'est pourquoi la gestion des correctifs est non négociable.

Made with GAMMA

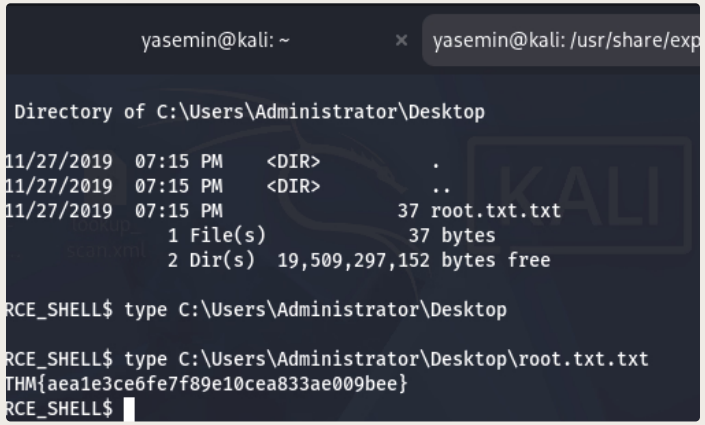
Escalade de privilèges : accès administrateur

Élévation du contrôle

Le web shell devient le point de départ d'un accès plus profond. En naviguant dans les répertoires administrateur, des identifiants sensibles et des fichiers de configuration deviennent accessibles.

- Accès aux répertoires administrateur via le web shell établi
- Localisation d'identifiants sensibles et de fichiers de configuration de l'application
- Obtention du contrôle administratif complet du système compromis

L'escalade de privilèges transforme un accès limité en possession totale du système — une phase critique que tout défenseur doit comprendre.



Made with GAMMA

```
┌──(yasemin㉿kali)-[~/Downloads]
└─$ impacket-secretsdump -sam SAM -system SYSTEM LOCAL
Impacket v0.14.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[*] Target system bootKey: 0x147a48de4a9815d2aa479598592b086f
[*] Dumping local SAM hashes (uid:rid:lmhash:nthash)
Administrator:500:aad3b435b51404eeaad3b435b51404ee:549a1bcb88e35dc18c7a0b0168631411:::
Guest:501:aad3b435b51404eeaad3b435b51404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Lab:1000:aad3b435b51404eeaad3b435b51404ee:30e87bf999828446a1c1209ddde4c450:::
[*] Cleaning up...
```

Extraction d'identifiants : vidage des clés de registre

Outil : reg.exe

Utilitaire intégré de Windows utilisé pour extraire les ruches de registre SYSTEM et SAM contenant les empreintes de mots de passe chiffrées des utilisateurs.

Pourquoi les clés de registre ?

La base SAM (Security Account Manager) stocke les identifiants hachés de tous les comptes utilisateurs locaux — le butin de toute compromission Windows.

Analyse hors ligne

Les hachages téléchargés sont transférés hors du système pour un déchiffrement hors ligne, évitant ainsi les mécanismes de détection en temps réel sur l'hôte cible.

Made with GAMMA

Craquage de hachage : récupération de mots de passe



Craquage des hachages

Une fois les hachages extraits de la base de données SAM, les outils de craquage hors ligne transforment les données chiffrées en identifiants en clair.

- **Hashcat** — craquage accéléré par GPU pour un déchiffrement rapide des hachages
- **John the Ripper** — craquage flexible basé sur des règles avec prise en charge des listes de mots
- Révèle avec succès des mots de passe en clair pour un accès ultérieur au système

⚠ Les mots de passe faibles ou réutilisés sont craqués en quelques secondes. Des politiques de mots de passe robustes et l'AMF sont les seules contre-mesures efficaces.

Made with GAMMA

Points clés pour les défenseurs



Corrigez immédiatement

Les logiciels CMS obsolètes constituent un point d'entrée critique. Corrigez les vulnérabilités dès la publication des mises à jour — OSCommerce 2.3.4 présentait des CVE connues avec des exploits publics.



Segmentez votre réseau

Mettez en place une segmentation du réseau pour contenir les mouvements latéraux après une compromission initiale. Un serveur compromis ne doit jamais devenir un tremplin vers tout le reste.



Surveillez activement

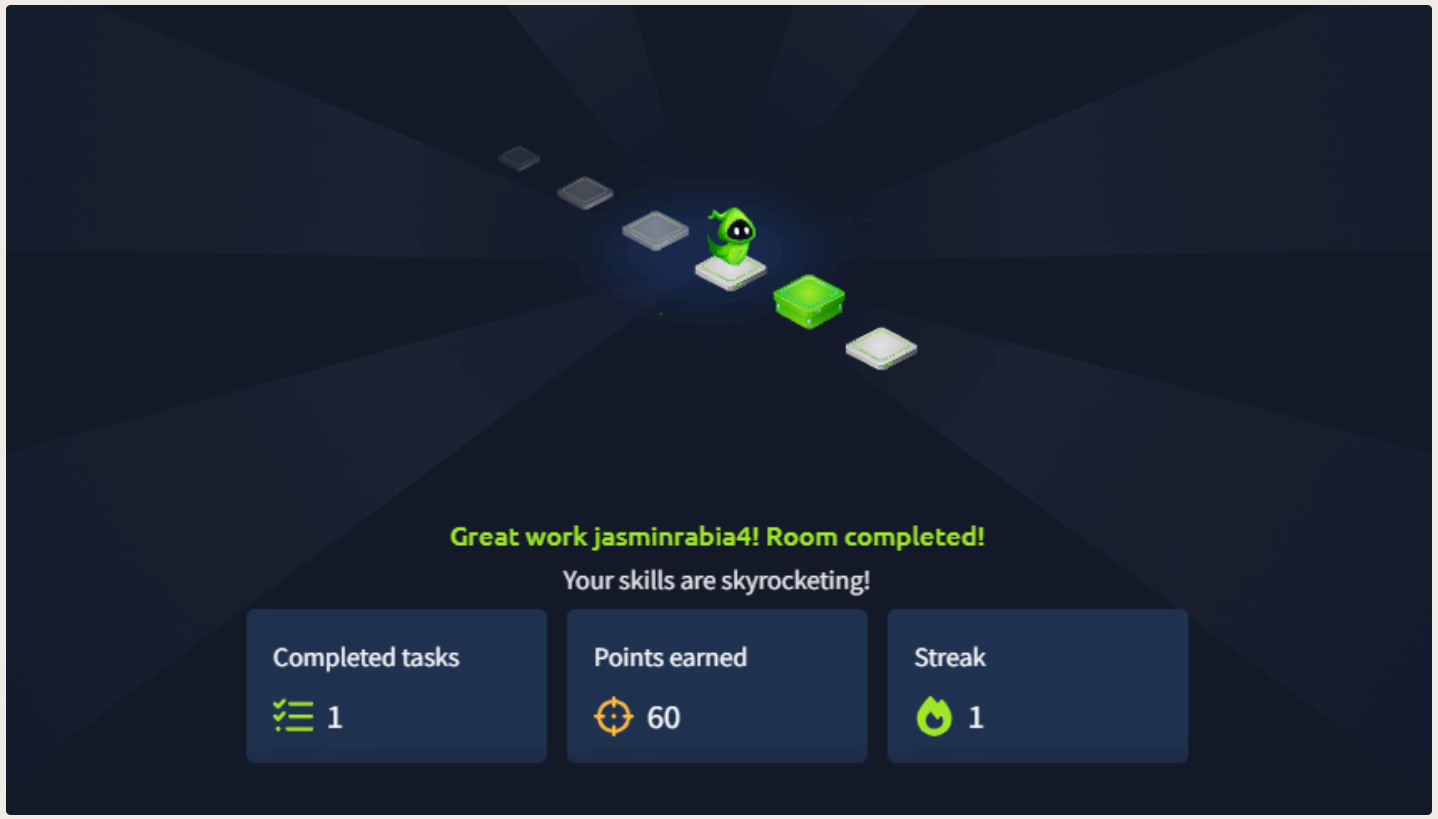
Surveillez les activités suspectes de web shell, les exécutions de processus inhabituelles et les appels reg.exe. La détection comportementale repère les attaquants que les outils basés sur les signatures ne détectent pas.



Renforcez l'authentification

Des politiques de mots de passe robustes et l'authentification multifacteur réduisent fortement l'impact de l'extraction d'identifiants — même des hachages cassés deviennent inutiles sans le second facteur.

Made with GAMMA



Défi terminé : compétences démontrées

Ce guide montre les compétences essentielles en tests d’intrusion tout au long de la chaîne d’attaque — de la reconnaissance initiale à l’extraction d’identifiants.

1

Reconnaissance

Analyse des ports et découverte des services

2

Identification des vulnérabilités

Empreinte du CMS et recherche de CVE

3

Exploitation

Exécution de code à distance via des scripts d’exploitation publics

4

Escalade de privilèges

Accès administrateur via la navigation dans le shell

5

Extraction d’identifiants

Récupération du registre et cassage des hachages

Made with GAMMA